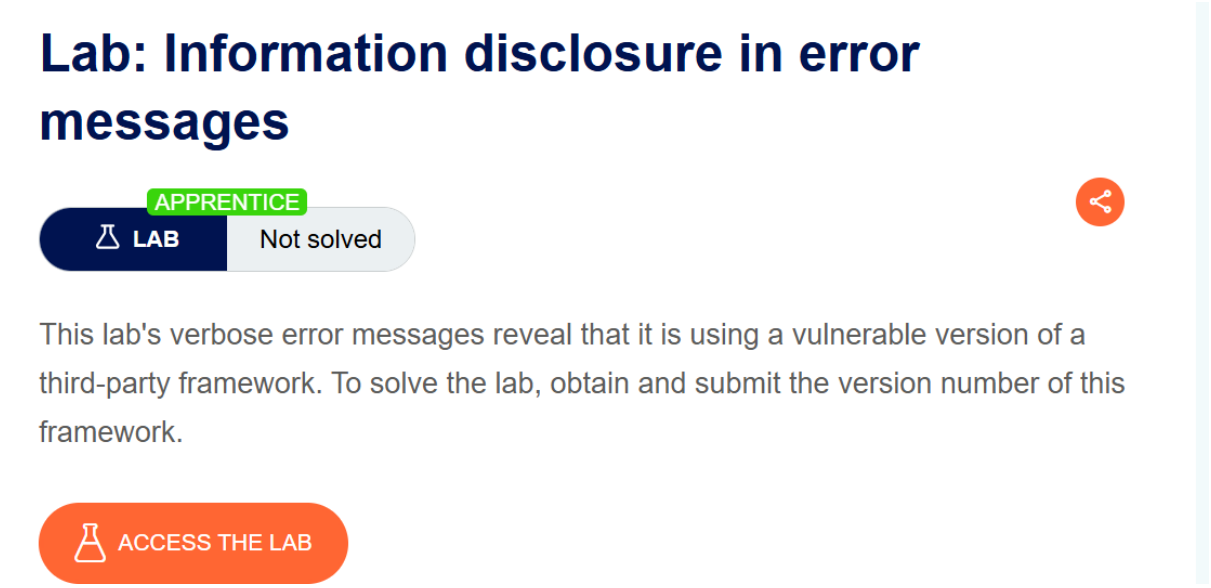
Day 36 Lab — Information Disclosure Through Error Messages

LAB PLATFORM

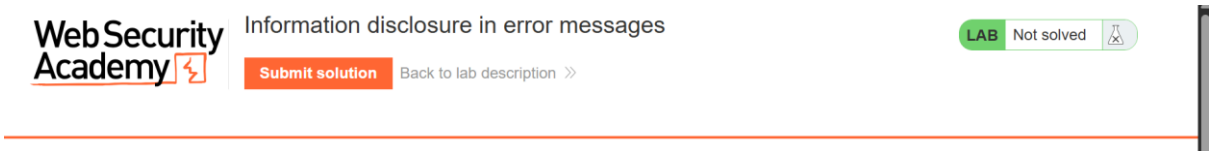
PortSwigger Web Security Academy — Official Lab: "Information disclosure in error messages"

https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-error-messages



LAB INSTRUCTIONS

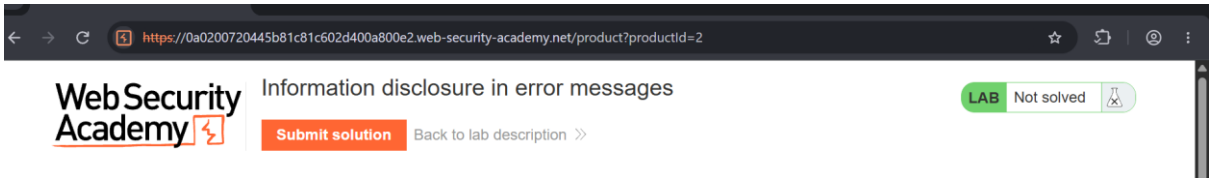
1. Open the official PortSwigger lab "Information disclosure in error messages".



2. Launch the intentionally vulnerable lab environment.

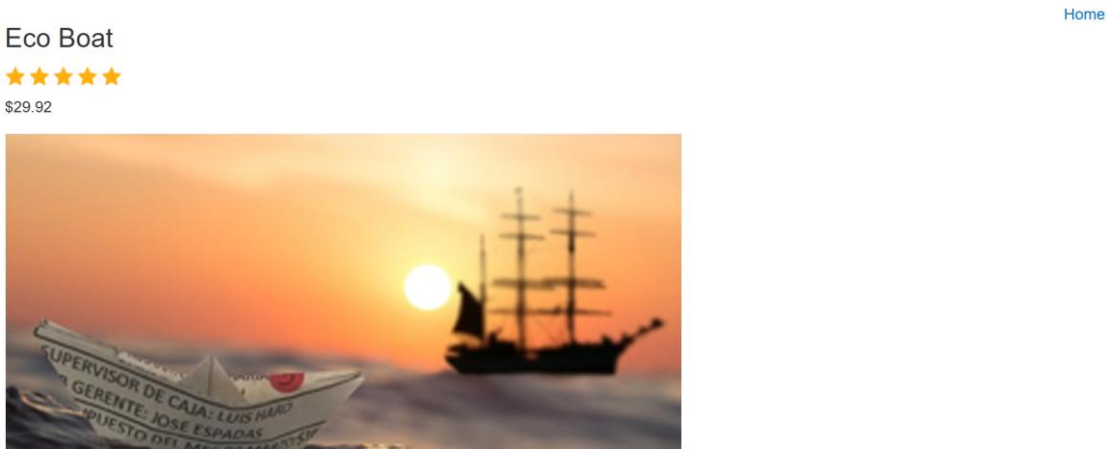
3. Open a product page.

4. Open Burp Suite.



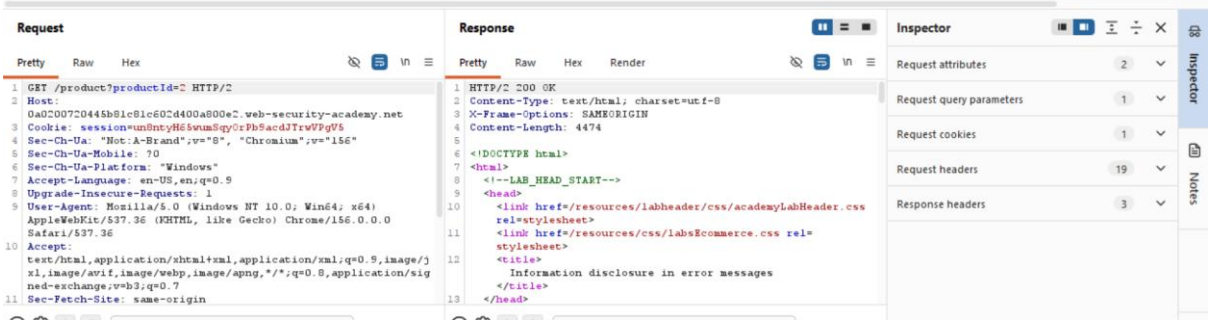
5. Review the product request in Proxy → HTTP History.

Day 36 Lab — Information Disclosure Through Error Messages



6. Identify the productId-style parameter used by the training lab.

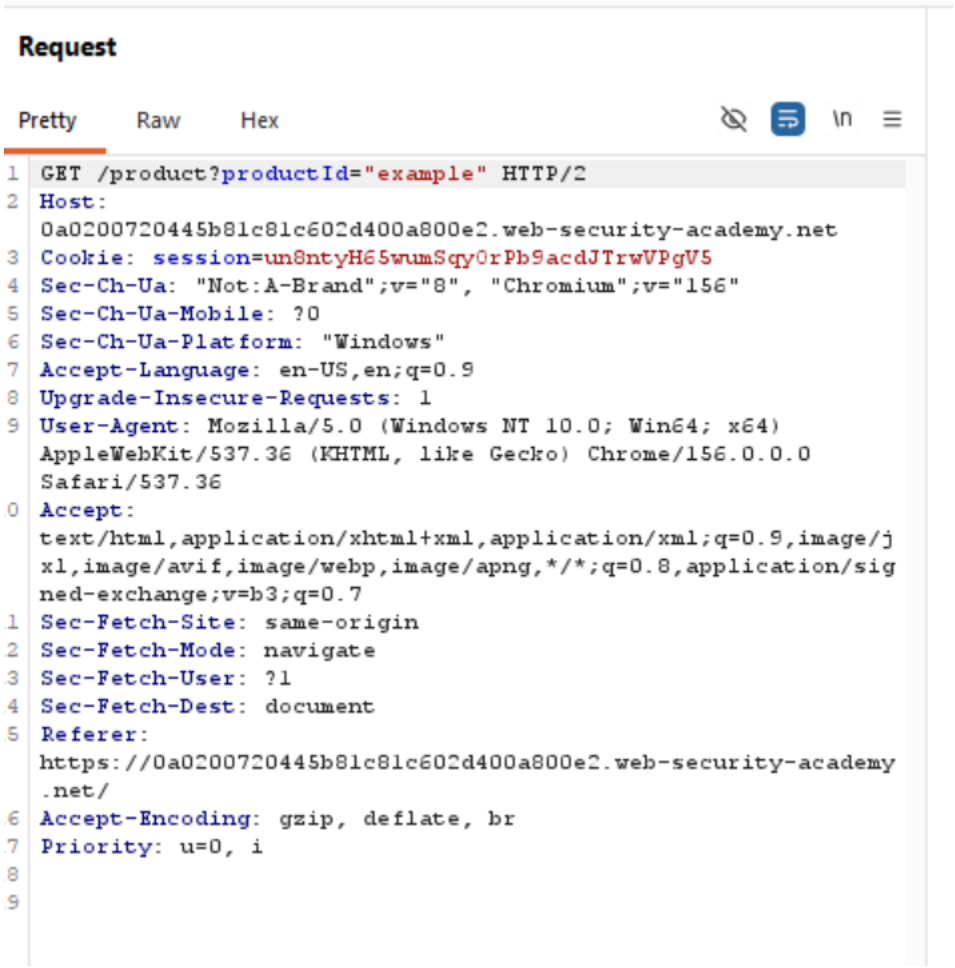




7. Send the request to Burp Repeater.

8. Change the parameter to an intentionally unexpected data type only as required by the official lab exercise.

Day 36 Lab — Information Disclosure Through Error Messages

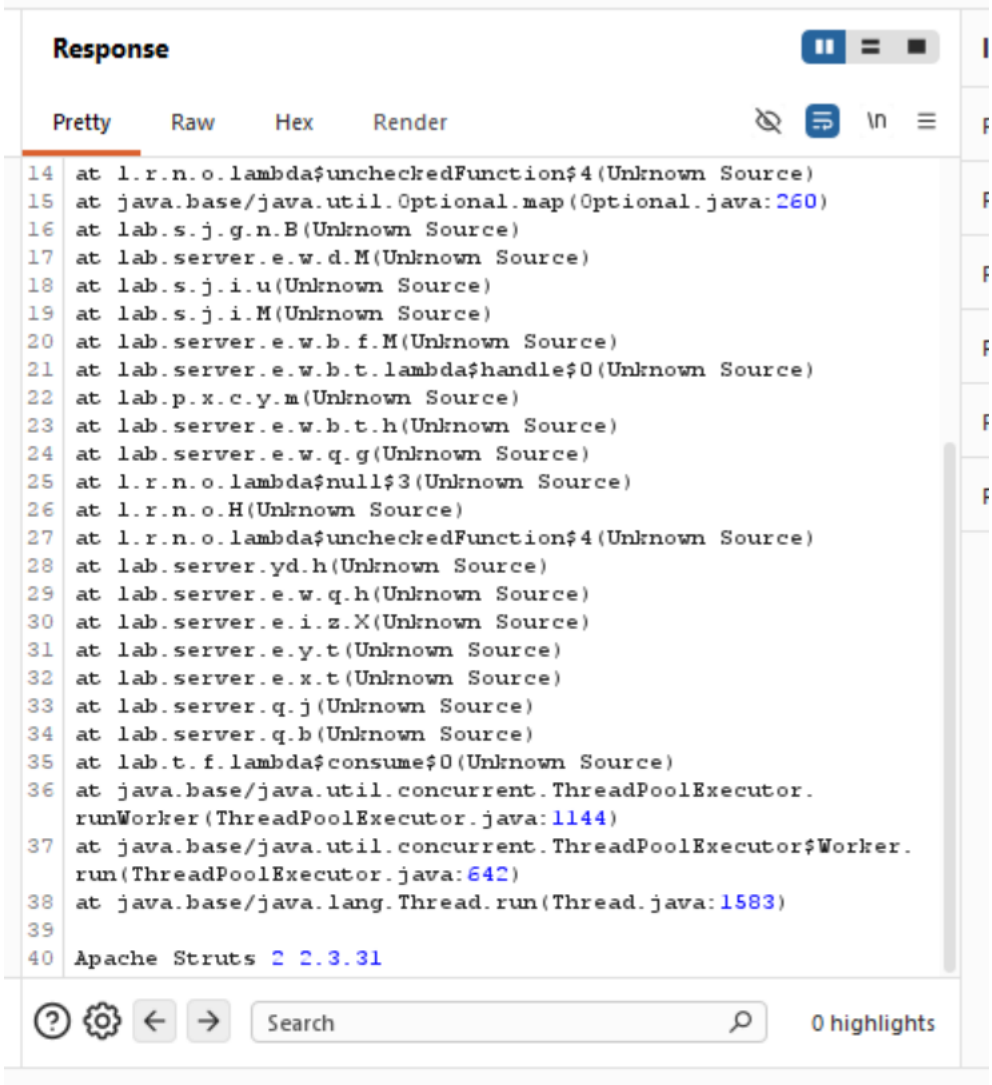


9. Send the training request.

10. Observe the resulting error response.

11. Identify the information revealed by the verbose error (stack trace, framework information, version information, internal technical details).

Day 36 Lab — Information Disclosure Through Error Messages



12. Complete the official lab.



13. Capture screenshots.

Day 36 Lab — Information Disclosure Through Error Messages



14. Explain why this information should not normally be shown to production users.

LAB TASKS

Task 1: Capture the normal product request.

Task 2: Identify the relevant parameter.

Task 3: Observe the error caused inside the authorized training environment.

Task 4: List the technical information revealed.

The error response revealed version information about the application.

- Stack traces.
- Framework information.
- Software version details.
- Internal technical information.
- Database or server error details.

Task 5: Classify the issue (verbose error / information disclosure / exceptional-condition handling).

The issue can be classified as:

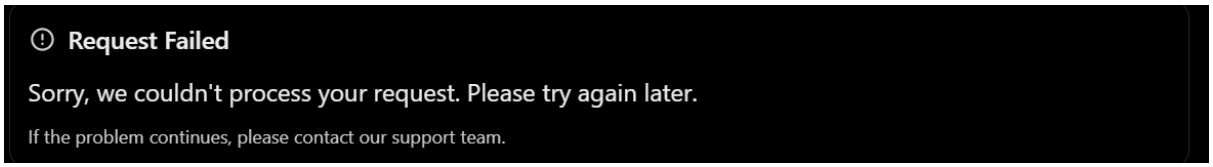
- **Verbose Error:** The application displays excessive technical details in its error response.
- **Information Disclosure:** Internal application information is exposed to users.
- **Exceptional-condition Handling:** The application does not handle unexpected input safely.

Task 6: Explain how such information could help an attacker.

- Attackers can identify the application's framework and software versions.
- They may use this information to research known vulnerabilities and technical details can help attackers understand the application's internal structure and plan further attacks.

Day 36 Lab — Information Disclosure Through Error Messages

Task 7: Design a safer user-facing response.



Task 8: Explain what information should instead be stored in protected internal logs.

- Timestamp of the error.
- Error type and error code.
- Affected endpoint and request details.
- Stack trace and relevant diagnostic information.
- Request or correlation ID for investigation.
- Relevant user or session identifier, where appropriate and safely handled.

Task 9: Give at least five recommended mitigations.

- Use generic error messages for production users.
- Disable detailed debugging errors in production environments.
- Validate input parameters on the server side.
- Store detailed error information in protected internal logs.
- Keep frameworks and software dependencies updated.
- Apply proper exception handling throughout the application.